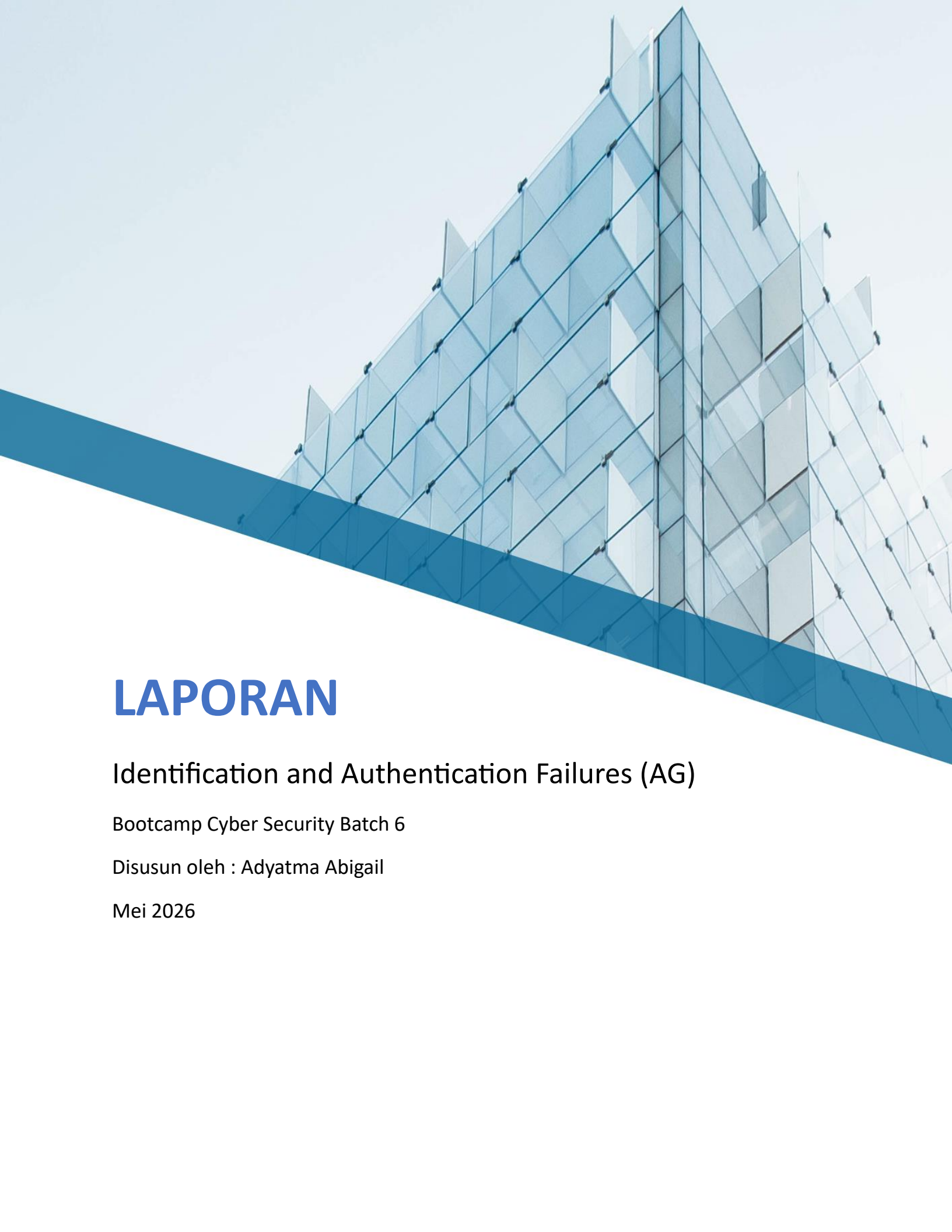




# LAPORAN

## Identification and Authentication Failures (AG)

Bootcamp Cyber Security Batch 6

Disusun oleh : Adyatma Abigail

Mei 2026

# ***kebijakan proses autentikasi yang aman untuk aplikasi berbasis web***

## **Persyaratan teknis untuk password :**

- Panjang minimum password: biasanya minimal 8–12 karakter, karena semakin panjang password maka semakin sulit di-crack.
- Menggunakan huruf besar dan kecil: kombinasi kapital dan huruf kecil meningkatkan kompleksitas password.
- Mengandung angka: misalnya 0–9 untuk menambah variasi karakter.
- Menggunakan karakter khusus: seperti @, #, !, %, &, dan lainnya agar password lebih aman.
- Tidak menggunakan informasi pribadi: seperti nama, tanggal lahir, atau nomor telepon karena mudah ditebak.
- Tidak menggunakan kata umum: misalnya “password123” atau “admin”.
- Password harus unik: tidak menggunakan password yang sama di banyak akun.
- Masa berlaku password: pada beberapa sistem, password harus diganti secara berkala.
- Riwayat password: sistem biasanya melarang penggunaan ulang password lama.

Contoh password yang kuat:

K4m!S3cur3#2026

## **Aturan pengelolaan password :**

- Periode pergantian password: password harus diganti secara berkala, misalnya setiap 60–90 hari, terutama pada akun penting atau sistem perusahaan.
- Pencegahan penggunaan ulang password: pengguna tidak diperbolehkan memakai kembali beberapa password terakhir agar tidak terus menggunakan password lama yang mungkin sudah bocor.
- Penyimpanan password secara aman: password tidak boleh disimpan dalam bentuk teks biasa (plain text), melainkan harus dienkripsi atau menggunakan hashing seperti bcrypt atau SHA-256.

- Larangan membagikan password: password bersifat rahasia dan tidak boleh diberikan kepada orang lain.
- Penggunaan password manager: disarankan menggunakan aplikasi pengelola password agar penyimpanan lebih aman dan pengguna tidak perlu mengingat banyak password.
- Aktivasi autentikasi tambahan: seperti Multi-Factor Authentication (MFA) untuk meningkatkan keamanan selain password.
- Penguncian akun otomatis: akun akan terkunci sementara jika terjadi terlalu banyak percobaan login gagal untuk mencegah brute force attack.
- Reset password yang aman: proses reset harus menggunakan verifikasi identitas seperti email, OTP, atau autentikasi tambahan.
- Monitoring kebocoran password: sistem dapat memeriksa apakah password pernah muncul dalam database kebocoran data.

## **Strategi mitigasi terhadap serangan seperti brute force, credential stuffing, dan phishing.**

Strategi mitigasi terhadap serangan seperti brute force, credential stuffing, dan phishing dilakukan dengan kombinasi teknologi, kebijakan keamanan, dan edukasi pengguna. Untuk menghadapi brute force attack, sistem biasanya menerapkan pembatasan percobaan login, penguncian akun sementara, CAPTCHA, serta penggunaan password yang kuat dan kompleks. Pada serangan credential stuffing, mitigasi dilakukan dengan penggunaan password unik di setiap akun, penerapan Multi-Factor Authentication (MFA), monitoring login mencurigakan, dan deteksi kebocoran kredensial. Sedangkan untuk mengurangi risiko phishing, organisasi perlu memberikan edukasi keamanan kepada pengguna, menggunakan filter email anti-phishing, memverifikasi alamat situs atau email sebelum login, serta menerapkan MFA agar akun tetap aman meskipun password berhasil dicuri. Selain itu, penggunaan enkripsi, sistem monitoring keamanan, dan pembaruan sistem secara rutin juga menjadi langkah penting dalam memperkuat perlindungan terhadap berbagai jenis serangan tersebut.

## **Prosedur untuk autentikasi tambahan.**

Prosedur autentikasi tambahan seperti **Two-Factor Authentication (2FA)** dilakukan untuk menambah lapisan keamanan selain penggunaan password. Prosesnya dimulai ketika pengguna memasukkan username dan password seperti biasa. Setelah data login benar, sistem akan meminta verifikasi kedua sebagai faktor tambahan. Faktor ini bisa berupa kode OTP yang dikirim melalui SMS atau email, kode dari aplikasi autentikasi seperti Google Authenticator atau

Microsoft Authenticator, notifikasi persetujuan login, sidik jari, pengenalan wajah, atau perangkat keamanan khusus. Pengguna kemudian memasukkan kode atau menyetujui verifikasi tersebut agar akses diberikan. Jika faktor kedua gagal diverifikasi, sistem akan menolak login meskipun password benar. Selain itu, biasanya tersedia kode cadangan (backup code) untuk keadaan darurat ketika perangkat autentikasi hilang atau tidak dapat digunakan. Prosedur ini bertujuan untuk mencegah akses tidak sah apabila password pengguna berhasil dicuri atau bocor.

## **Penjelasan bagaimana kebijakan ini dapat diimplementasikan dalam aplikasi web.**

Kebijakan keamanan password dan autentikasi dapat diimplementasikan dalam aplikasi web melalui beberapa mekanisme pada sisi server maupun sisi pengguna. Pertama, aplikasi menerapkan **validasi password** saat registrasi atau perubahan password, misalnya mewajibkan minimal panjang karakter, kombinasi huruf besar, angka, dan simbol khusus. Password kemudian disimpan secara aman menggunakan teknik hashing seperti bcrypt agar tidak tersimpan dalam bentuk asli. Sistem juga dapat menerapkan **kebijakan pergantian password** secara berkala serta mencegah pengguna memakai kembali password lama dengan menyimpan riwayat hash password sebelumnya.

Untuk mencegah serangan seperti brute force dan credential stuffing, aplikasi dapat membatasi jumlah percobaan login, memberikan CAPTCHA, serta melakukan penguncian akun sementara jika login gagal berkali-kali. Selain itu, aplikasi dapat memonitor aktivitas login mencurigakan seperti lokasi atau perangkat yang tidak biasa. Implementasi **Two-Factor Authentication (2FA)** dilakukan dengan meminta kode OTP melalui email, SMS, atau aplikasi autentikasi setelah password berhasil dimasukkan. Session pengguna juga perlu diamankan menggunakan token sesi yang terenkripsi, pengaturan timeout otomatis, dan penggunaan protokol HTTPS agar data login tidak mudah disadap.

Di sisi pengguna, aplikasi web dapat menyediakan fitur reset password yang aman menggunakan verifikasi email atau OTP, serta memberikan notifikasi jika terjadi login dari perangkat baru. Dengan penerapan kebijakan ini, aplikasi web menjadi lebih aman terhadap pencurian akun, akses ilegal, dan berbagai ancaman siber lainnya.